Seguridad, Rendimiento y Disponibilidad de Servicios e Infraestructuras

Ana I. González Acuña

Grado en Ingeniería Informática



2026/27

SRDSI

1. Introducción a la seguridad informática
2. Seguridad en la comunicación
3. Seguridad en los servicios
4. Seguridad Operacional



Tema 2: Seguridad en la comunicación



2 Seguridad en la comunicación
2.1 Protocolos seguros de comunicación
2.2 Nivel de Aplicación
2.3 Nivel de Transporte
2.4 Nivel de Interred
2.5 Nivel de Enlace



2 Seguridad en la comunicación
2.1 Protocolos seguros de comunicación
2.2 Nivel de Aplicación
2.3 Nivel de Transporte
2.4 Nivel de Interred
- IPsec
2.5 Nivel de Enlace



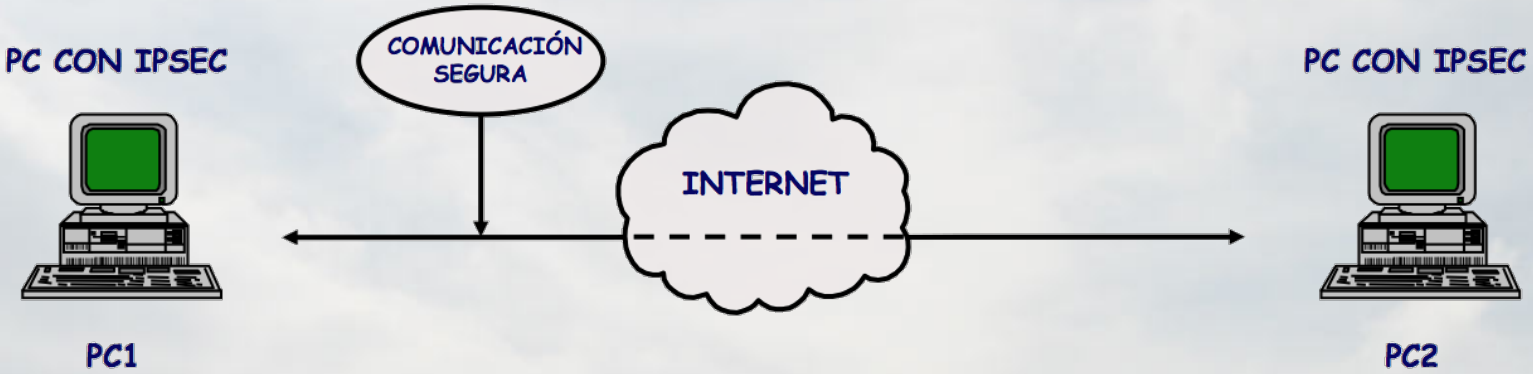
Internet Protocol **sec**ure v3(RFC 4301, 6071)

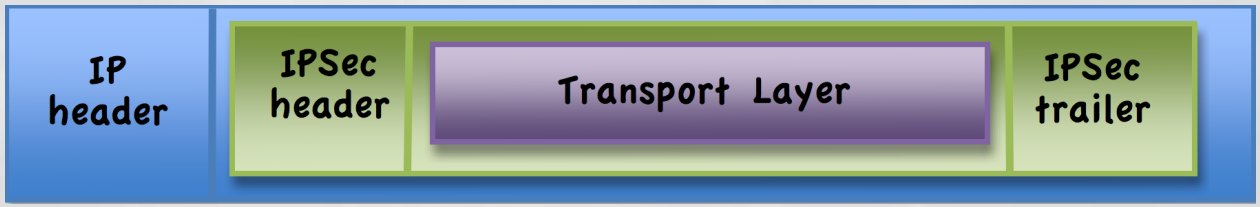
- Extensión al protocolo IP que proporciona servicios de seguridad en la capa de interred (TCP/IP):
  - Confidencialidad
  - Autenticación del emisor
  - Integridad de los datos
  - Control de accesos
- Estándar desarrollado por la IETF para IPv6 (recomendado), después fue portado a IPv4 (opcional)
- Usos:
  - Conectividad segura mediante VPN
  - Seguridad en las comunicaciones nodo-a-nodo, p.e: *routing protocols*
  - Mejora de la seguridad en el comercio electrónico



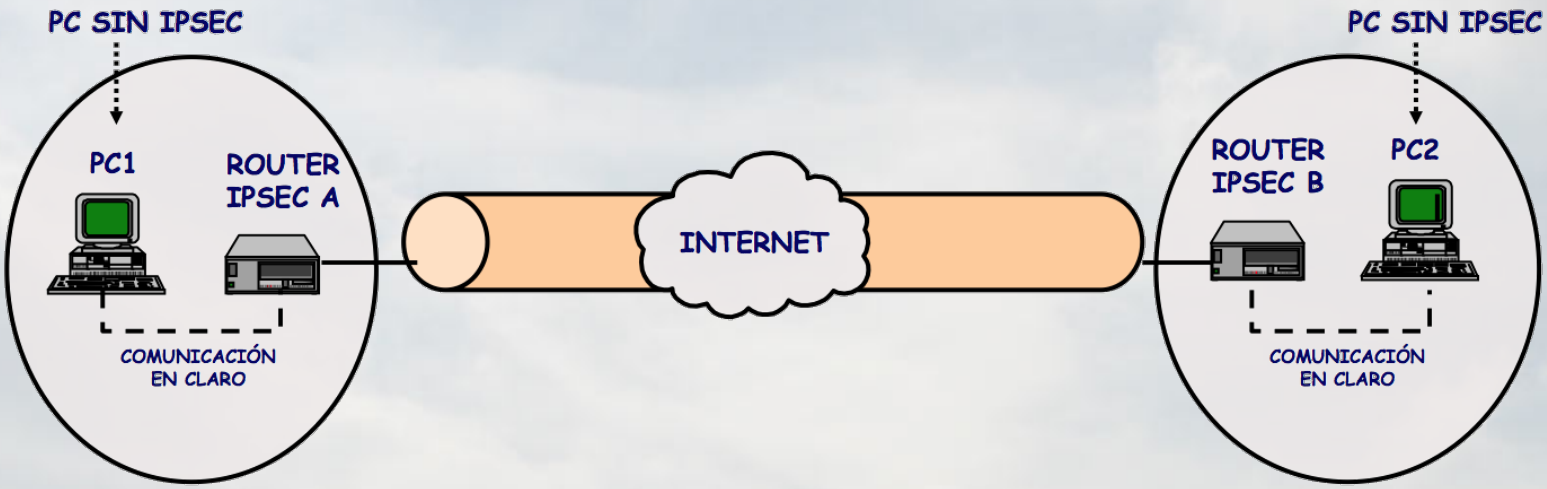
Modos de funcionamiento

- **Modo transporte:**
  - Proporciona protección a los protocolos de nivel superior
  - Usado generalmente en comunicaciones extremo a extremo entre dos *hosts (endpoint);* requieren software específico.





- **Modo túnel**:
  - Proporciona protección al datagrama completo
  - Usado en comunicaciones extremo a extremo entre dos dispositivos de red (*security gateways*).Transparente.
    - ★ Entre un host y un dispositivo de red.





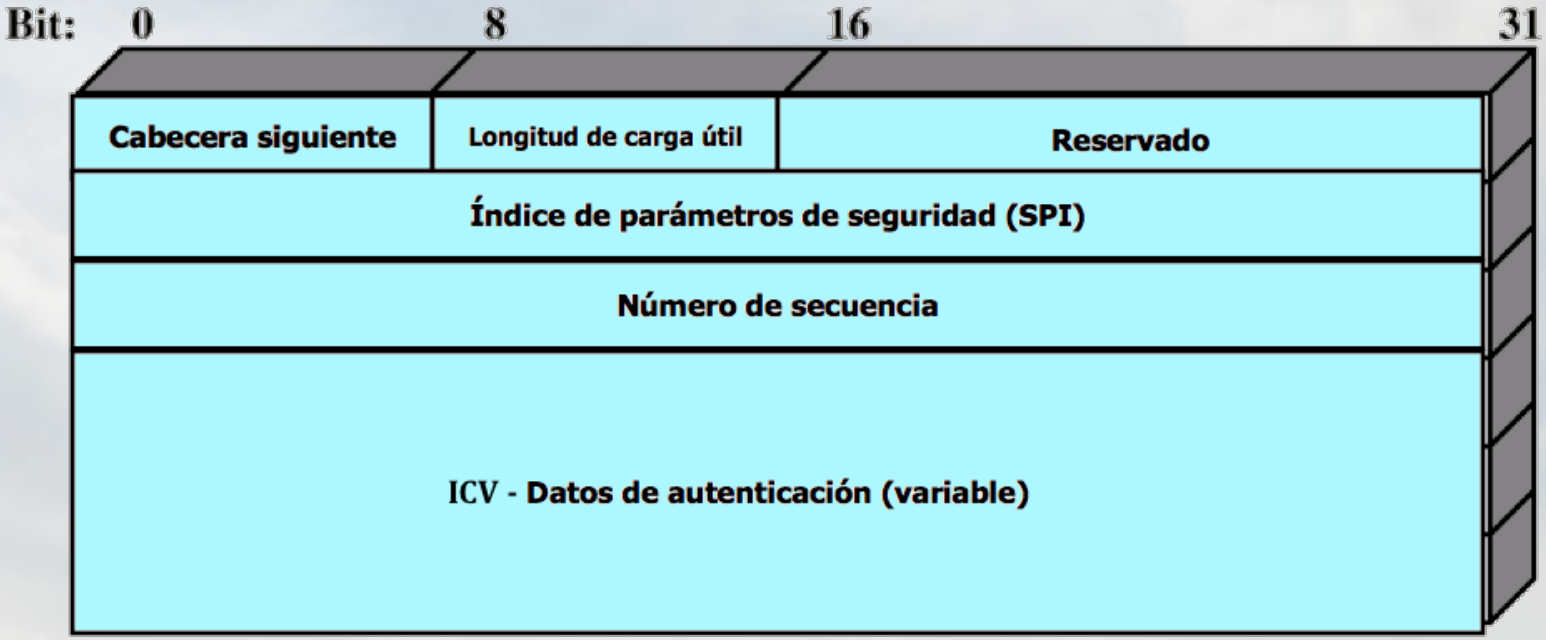
Componentes de IPsec

- Protocolos de seguridad:
  - **AH** (*Autentication Header*) proporciona autenticación e integridad
  - **ESP** (*Encapsulation Security Payload*) proporciona confidencialidad; autenticación, e integridad.
- Gestión de claves :
  - **IKEv2** (*Internet Key Exchange Protocol*) gestiona claves, realiza autenticación mutua, establece y mantiene asociaciones de seguridad (SA) (RFC 7296). **PAD**.
- Gestión de IPsec:
  - **SP** (*Security Policies*) gestión del uso de IPsec. **SPD**
  - **SA** (*Security Association*) para gestión de los parámetros de seguridad. **SAD**
- Algoritmos de autenticación y cifrado para AH y ESP (RFC 8221)
- IPcomp (*IP payload compression protocol*) (RFC 3173) proporciona compresión de los paquetes antes del cifrado ESP.

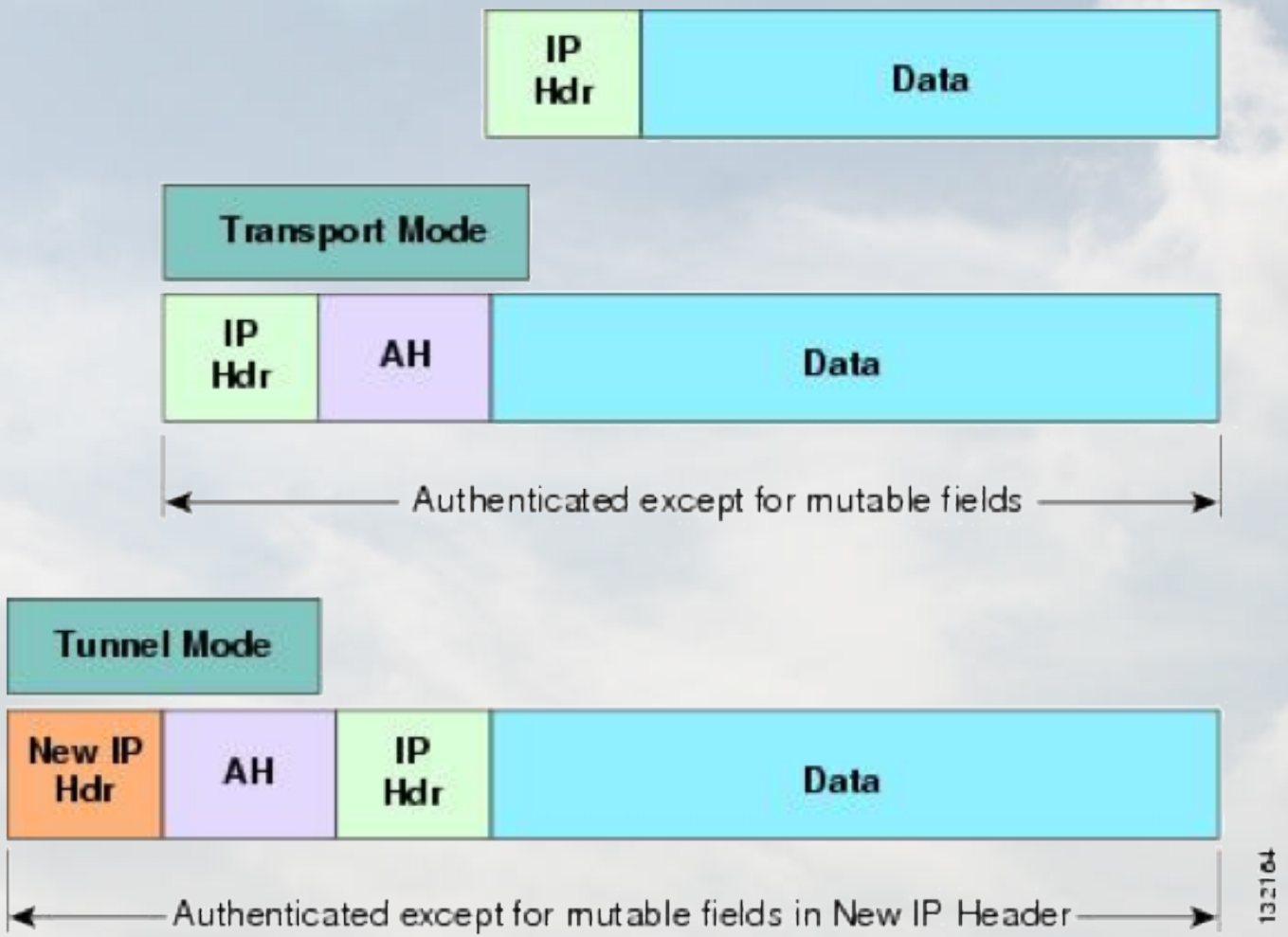


Autentication Header Protocol (RFC 4302)

Diseñado para autenticar al emisor y asegurar la integridad de los datos.
Opcional contra ataques de *replay*.



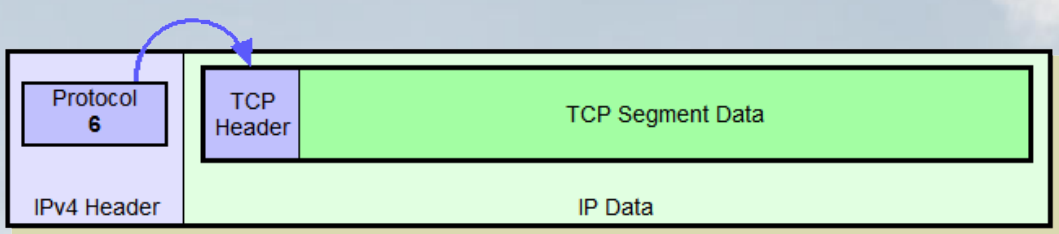
Integrity Check Value = HMAC_K (Cabecera sig. || Longitud || Reservado=0 || SPI || Numsec || ICV=0 || [Datagrama IP - campos variables de cabecera IP])



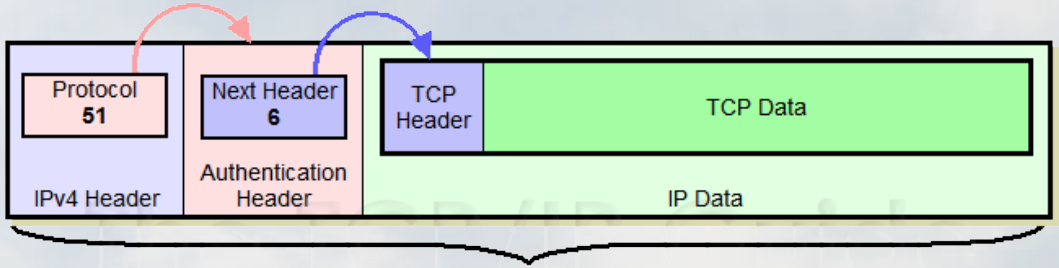
fuente: www.cisco.com



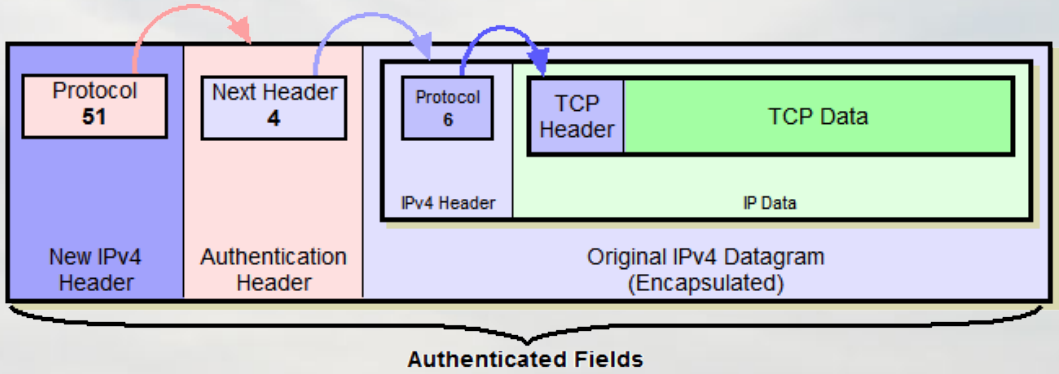
en detalle



Original IPv4 Datagram Format



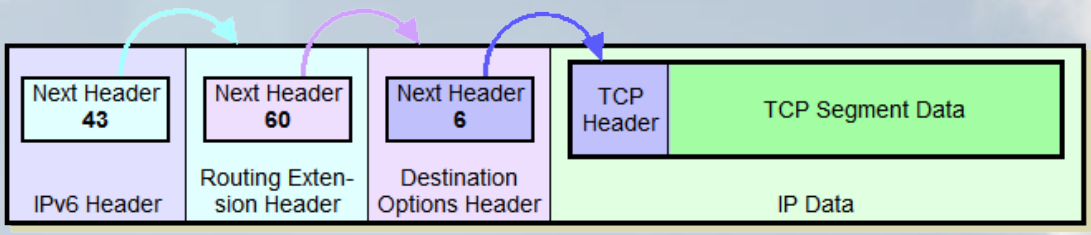
IPv4 AH Datagram Format - IPSec Transport Mode



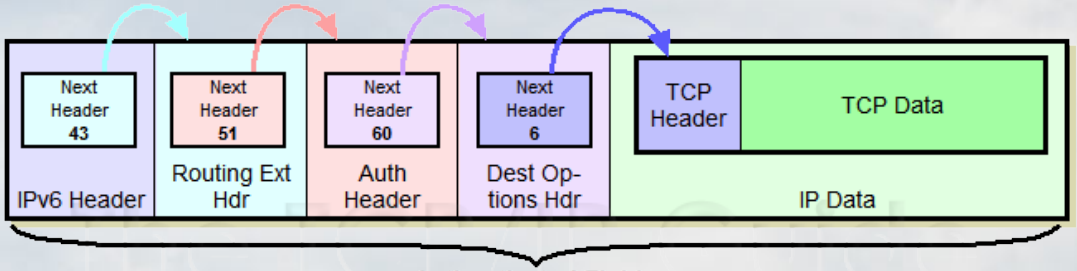
IPv4 AH Datagram Format - IPSec Tunnel Mode



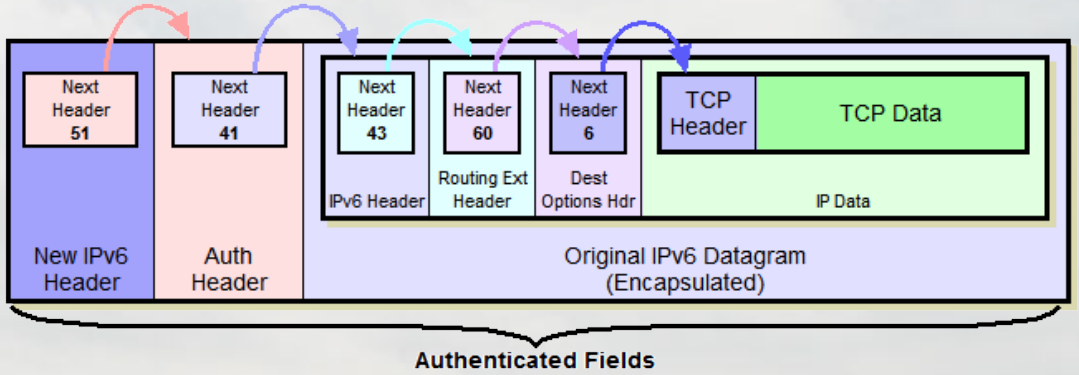
fuente: www.tcpipguide.com



Original IPv6 Datagram Format (Including Routing Extension Header and Destination-Specific Destination Options Extension Header)



IPv6 AH Datagram Format - IPSec Transport Mode

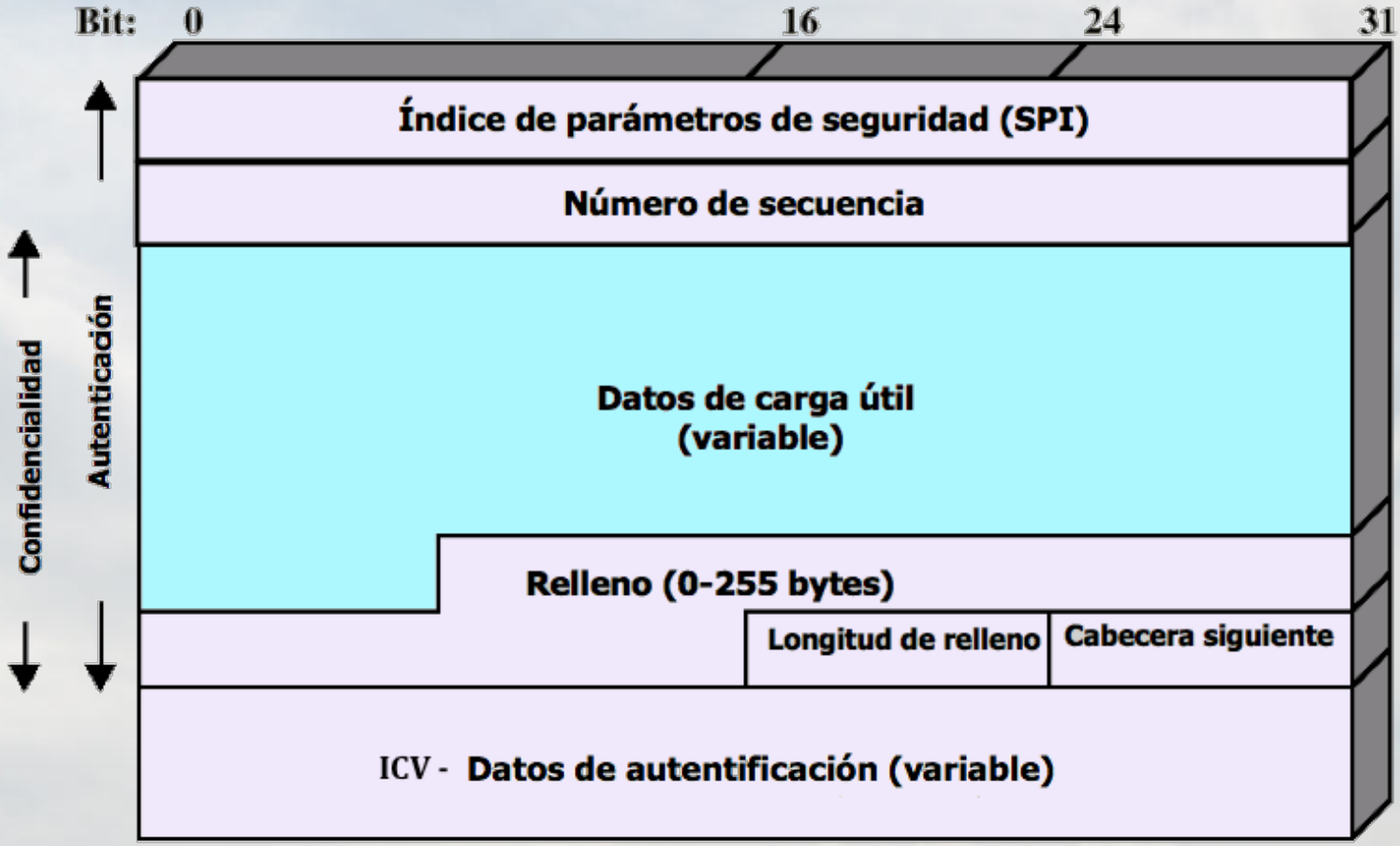


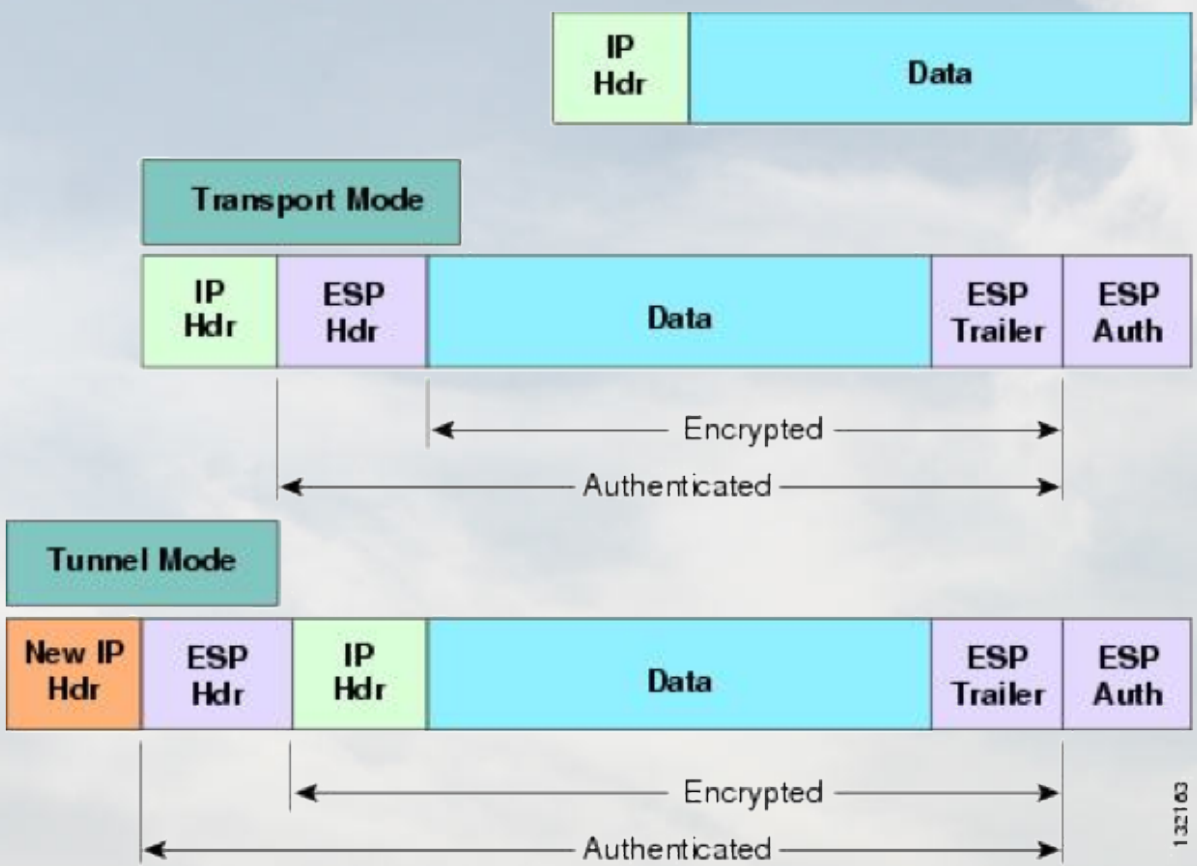
IPv6 AH Datagram Format - IPSec Tunnel Mode

fuente: www.tcpipguide.com

Encapsulation Security Payload Protocol (RFC 4303)

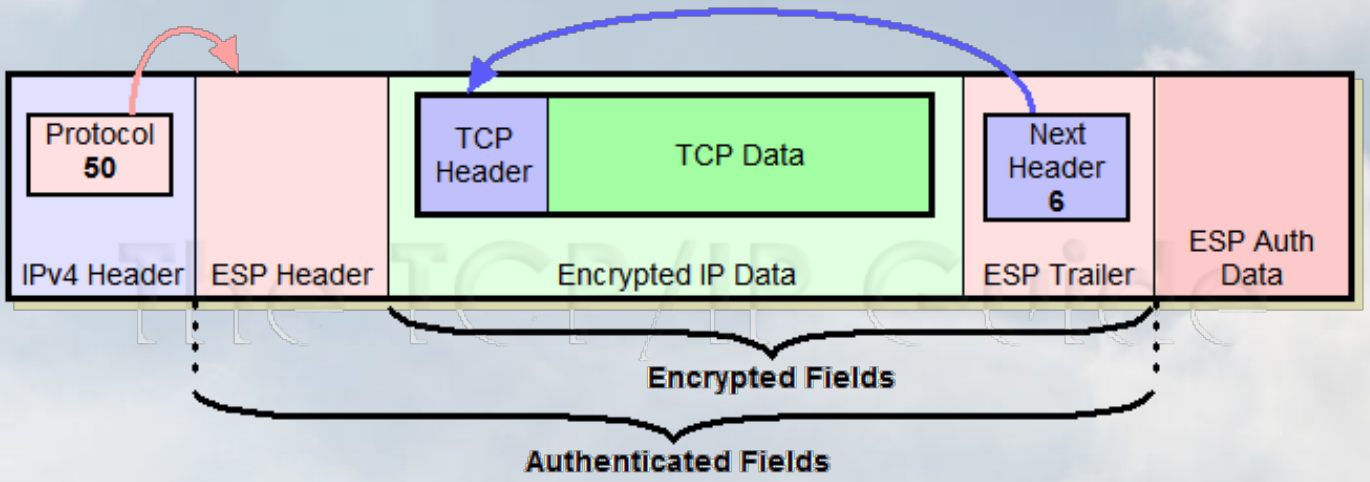
Diseñado para proporcionar confidencialidad. Opcionalmente autenticación del emisor, integridad y *anti-replay attacks.*



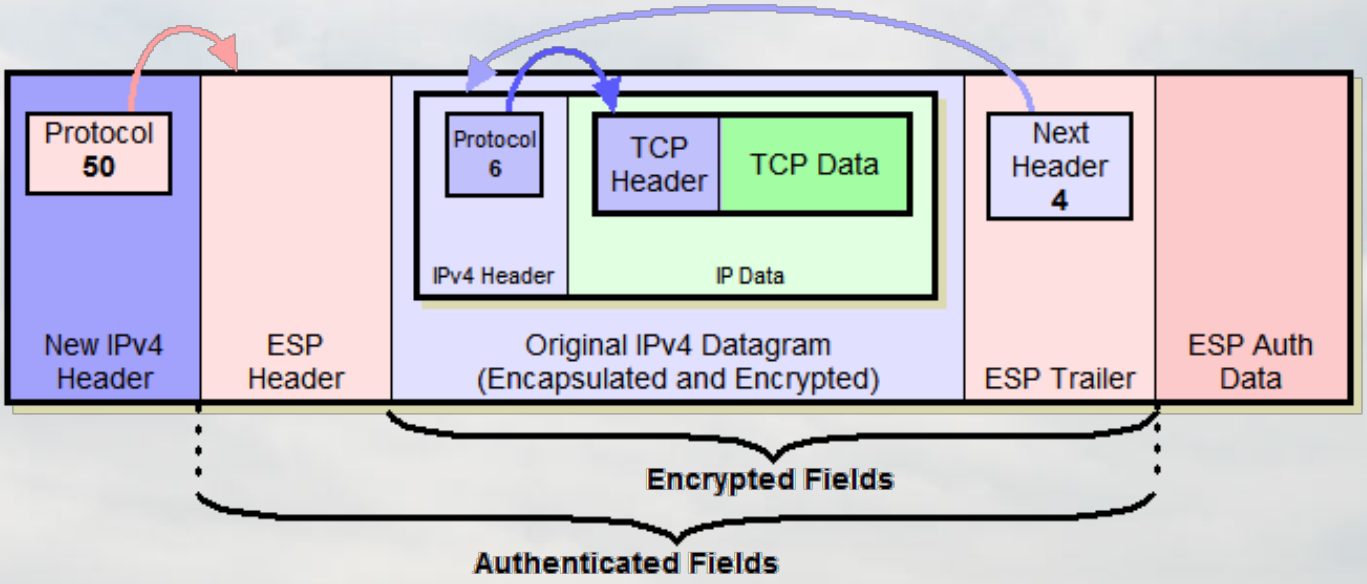


fuente: www.cisco.com



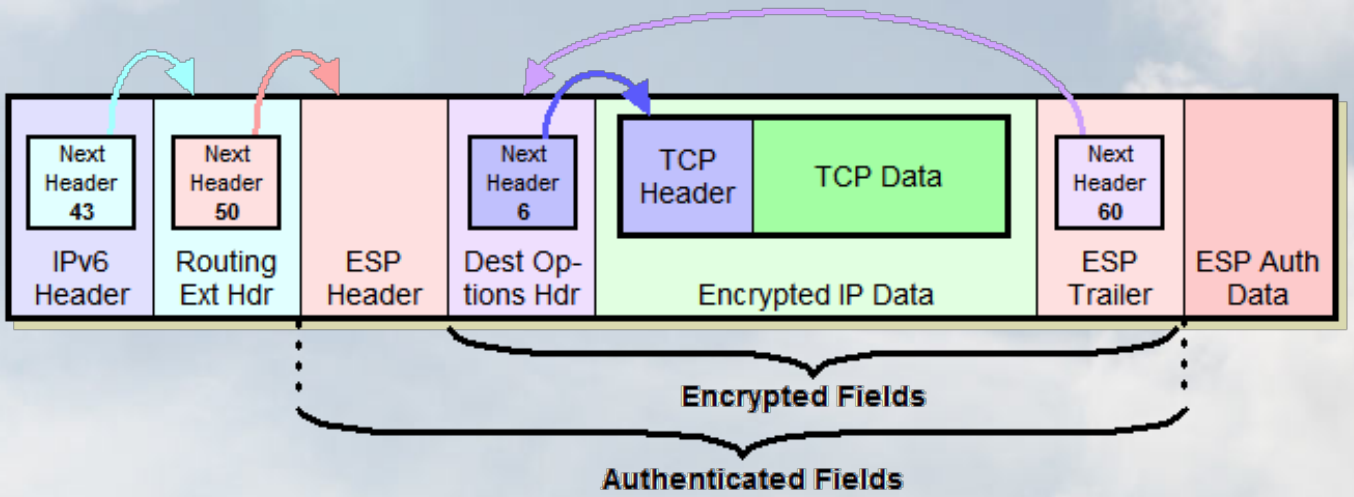


IPv4 ESP Datagram Format - IPSec Transport Mode

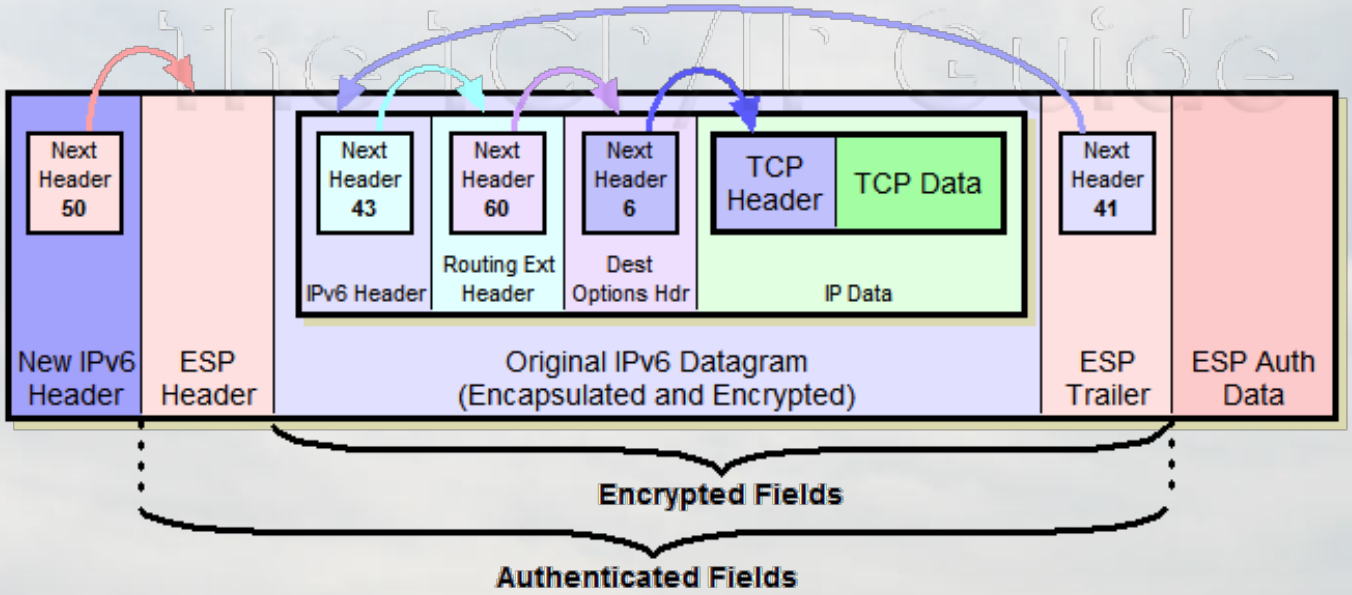


IPv4 ESP Datagram Format - IPSec Tunnel Mode

fuente: www.tcpipguide.com



IPv6 ESP Datagram Format - IPSec Transport Mode



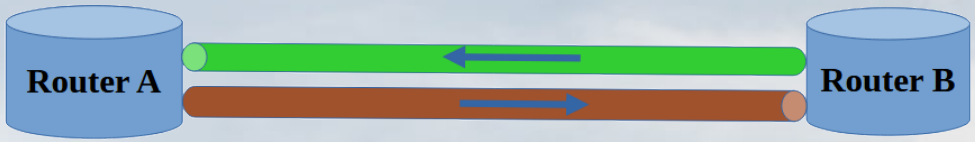
IPv6 ESP Datagram Format - IPSec Tunnel Mode

fuente: www.tcpipguide.com

Security Association (SA) (RFC 4301)

- Es una **conexión lógica** entre emisor y receptor para crear un canal **unidireccional seguro** entre ambos.
- Identificación unicast SA:
  - *Security Parameters Index* (SPI): 32 bits, equivale a un puerto TCP o UDP
  - [Identificador del protocolo de seguridad (AH o ESP)]
- Admite multicast SA
- Incluye los parámetros necesarios para la comunicación segura sobre una conexión: protocolo de seguridad, **modo**, algoritmos de cifrado y autenticación de datos, clave de sesión, ...
- Información sobre SAs (*SA Database*):
  - *Outbound SAD*, SAs para construir paquetes a enviar
  - *Inbound SAD*, SAs para procesar paquetes recibidos





Router A SAD

INBOUND SA SPI:1001
- IP destino A
- Tunnel mode con ESP
- Cifrado con AES-GCM
- . . .

OUTBOUND SA SPI:1002
- IP destino B
- Tunnel mode con ESP
- Cifrado con AES
- . . .

Router B SAD

OUTBOUND SA SPI:2005
- IP destino A
- Tunnel mode con ESP
- Cifrado con AES-GCM
- . . .

INBOUND SA SPI:2006
- IP destino B
- Tunnel mode con ESP
- Cifrado con AES
- . . .



Security Association Database (SAD)

Contiene los parámetros asociados a cada SA activa (*inboud/outbound*) necesarios para cifrar/descifrar, autenticar o verificar paquetes.

Index	SN	OF	ARW	AH/ ESP	LT	Mode	MTU
< SPI, DA, P >							
• • •							
< SPI, DA, P >							

Security Association Database

SN: Sequence number
OF: Overflow flag
ARW: Anti-replay window
AH/ESP: Information
LT: Lifetime
Mode: IPSec mode flag
MTU: Path MTU
SPI: Security parameter index
DA: Destination address
P: Protocol

fuente: web.engr.oregonstate.edu/~yavuza/



Security Policy Database (SPD)

- *Security Policy* (SP):
  Determina la política de seguridad que se aplica a todo el tráfico IP entrante y saliente de un dispositivo. Antes de usar SAD, es necesario que el administrador configure la política predefinida para cada tipo de tráfico:
  DISCARD / BYPASS IPsec / PROTECT using IPsec
- SPD: BD ordenada, con tres partes:
  Secure traffic SPD / Inbound SPD / Outbound SPD

Index	Policy
< SA, DA, Name, P, SPort, DPort >	
• • •	
< SA, DA, Name, P, SPort, DPort >	

SA: Source address
DA: Destination address
P: Protocol
SPort: Source port
DPort: Destination port



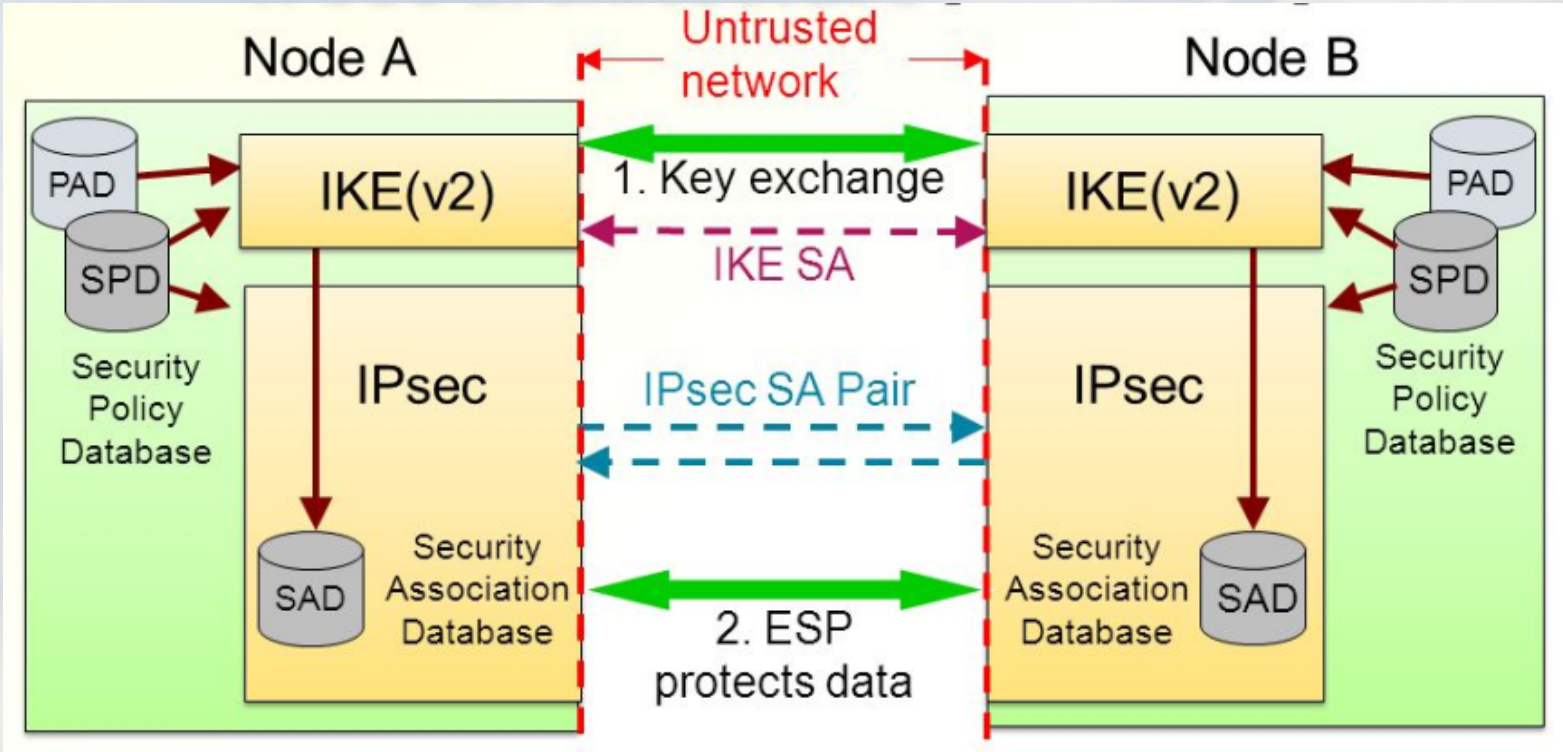
Peer Authorization Database (PAD)

- Establece una relación entre un *peer* y el método de autenticación a utilizar.
- Configurada por el administrador (al igual que la SPD).
- Una entrada por cada *peer* autorizado a comunicarse por IPsec:
  - Protocolo de autenticación (IKEv2, ...)
    - ★ método: certificados x509 o PSK
  - Datos de autenticación para cada *peer*
  - Determina ID para *SPD lookup* (IKE-ID / *remote IP address)*
  - Index: DNS name, DN, email-address, IPv4, IPv6, Key ID
- *Provides a link between an SA management protocol (such as IKE) and the SPD*



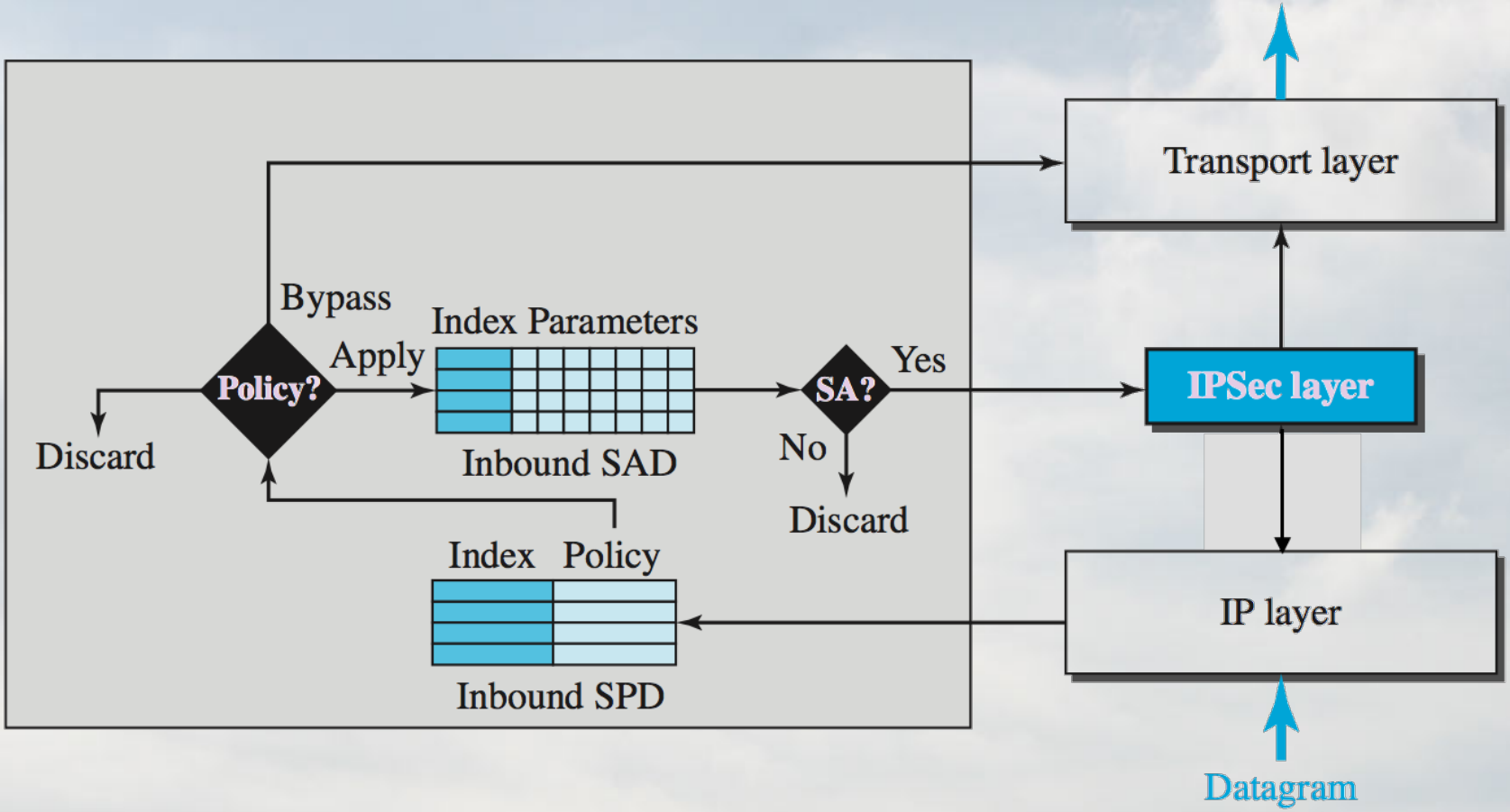
Arquitectura IPsec (RFC 4301)

Modelo general de procesamiento del tráfico IP relativo a IPsec



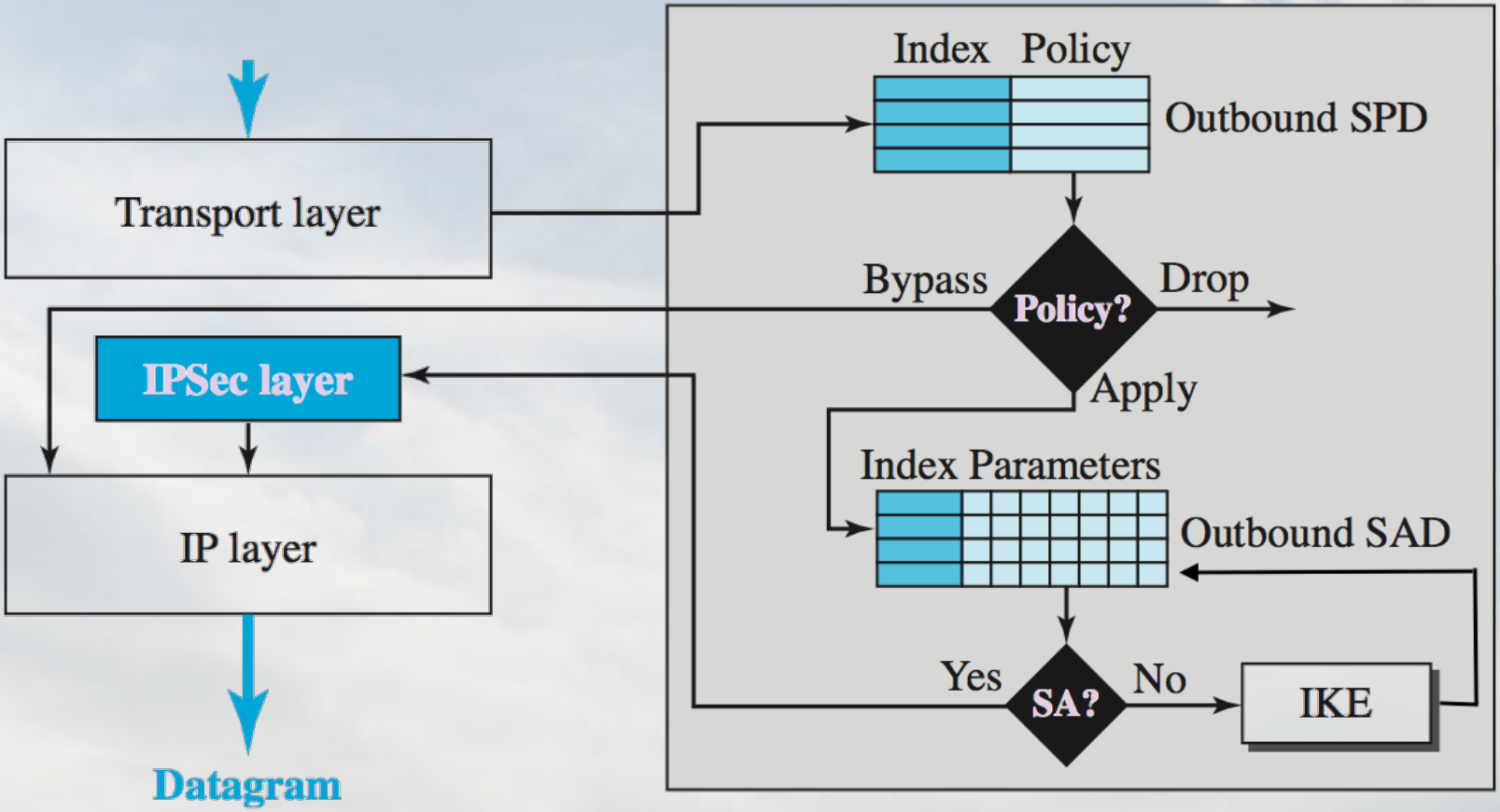
https://slideplayer.com/slide/10538818/

Inbound IP traffic processing



fuente: web.engr.oregonstate.edu/~yavuza/

Outbound IP traffic processing



fuente: web.engr.oregonstate.edu/~yavuza/

Gestión de SAs y claves

- Configuración manual, por el administrador, en los nodos IPsec:
  - Configuración manual de cada SA y parámetros criptográficos (algoritmos, claves...) relacionados
  - Solo práctico en entornos pequeños y estáticos. No escala bien
  - Claves estáticas (no recomendado s/RFC8221)
- Configuración automática: protocolo IKEv2
  - Autenticación mutua, establecimiento y mantenimiento de SAs.
  - Negociación de algoritmos criptográficos
  - *re-keying*

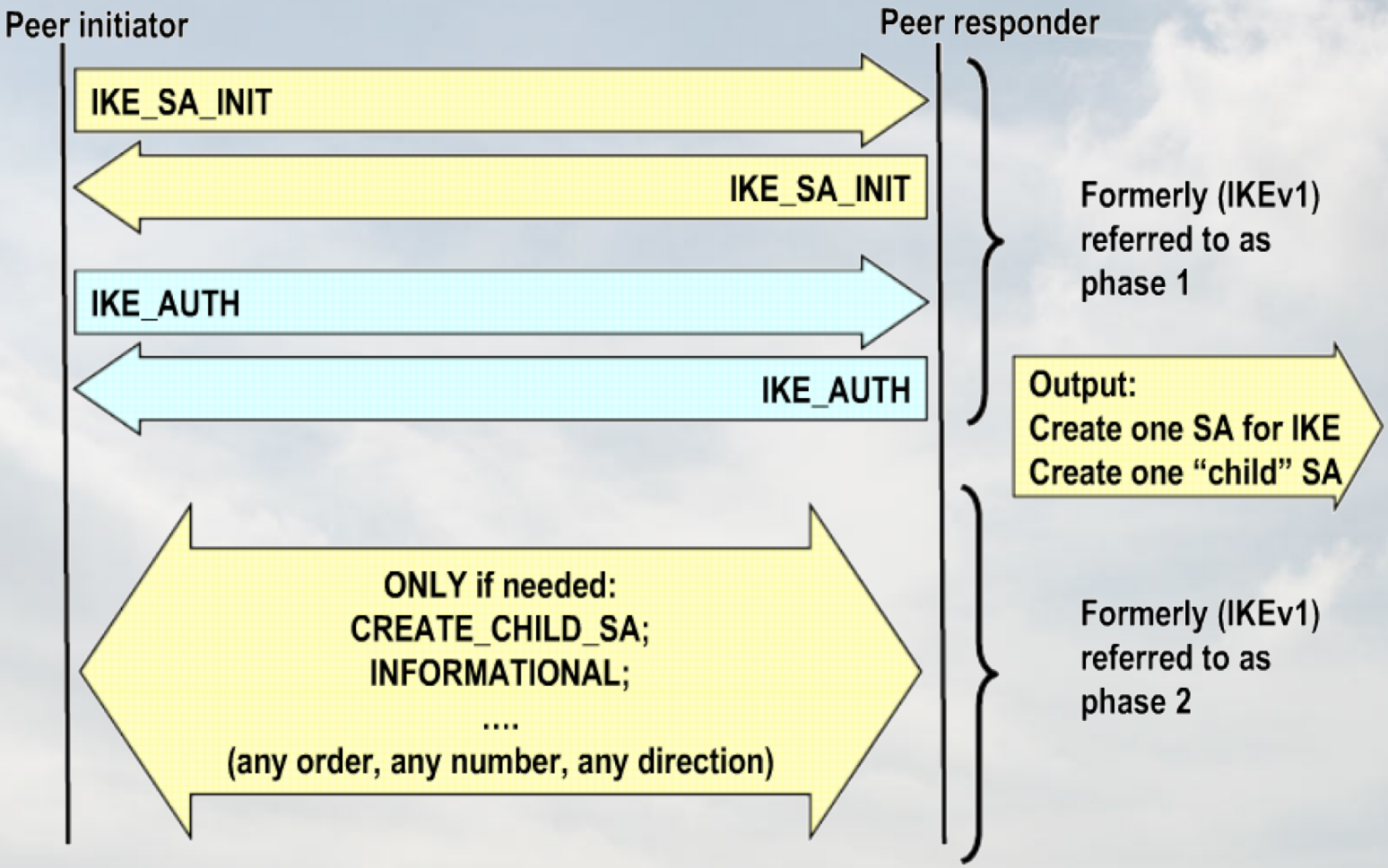


Internet Key Exchange v2 (RFC 7296 - STD 79)

- Utilizado para realizar autenticación mutua, establecer dinámicamente y mantener asociaciones de seguridad (SA). También para negociar el uso de IPComp.
- Autenticación en base a certificados X.509, o claves compartidas con anterioridad (*PSK - pre-shared key*)
- Cambio importante respecto a la versión anterior, que simplifica, mejora y aglutina varios protocolos (IKEv1, ISAKMP, Oakley ...) en uno solo . IKEv1 - Historic.
- Encapsulado en UDP (port 500)
  - Fiabilidad por retransmisión (*request/response pair*)
  - *Responder cookies*, para evitar DoS



Protocolo



fuente: Giuseppe Bianchi, IPsec Basics

Fase1, Paso1: IKE_SA_INIT

- Negociar algoritmos para IKE
- Calcular claves secretas para IKE. Creación IKE-SA
- Calcular *master-secret* para calcular las claves IPSec en fase 2

Fase1, Paso2: IKE_AUTH *

- Autenticación mutua
- Negociación de algoritmos IPSec (piggybacked). Creación IPSec-SA

Fase2: CREATE_CHILD_SA *

- Establecer nuevas asociaciones de seguridad AH o ESP

INFORMATIONAL

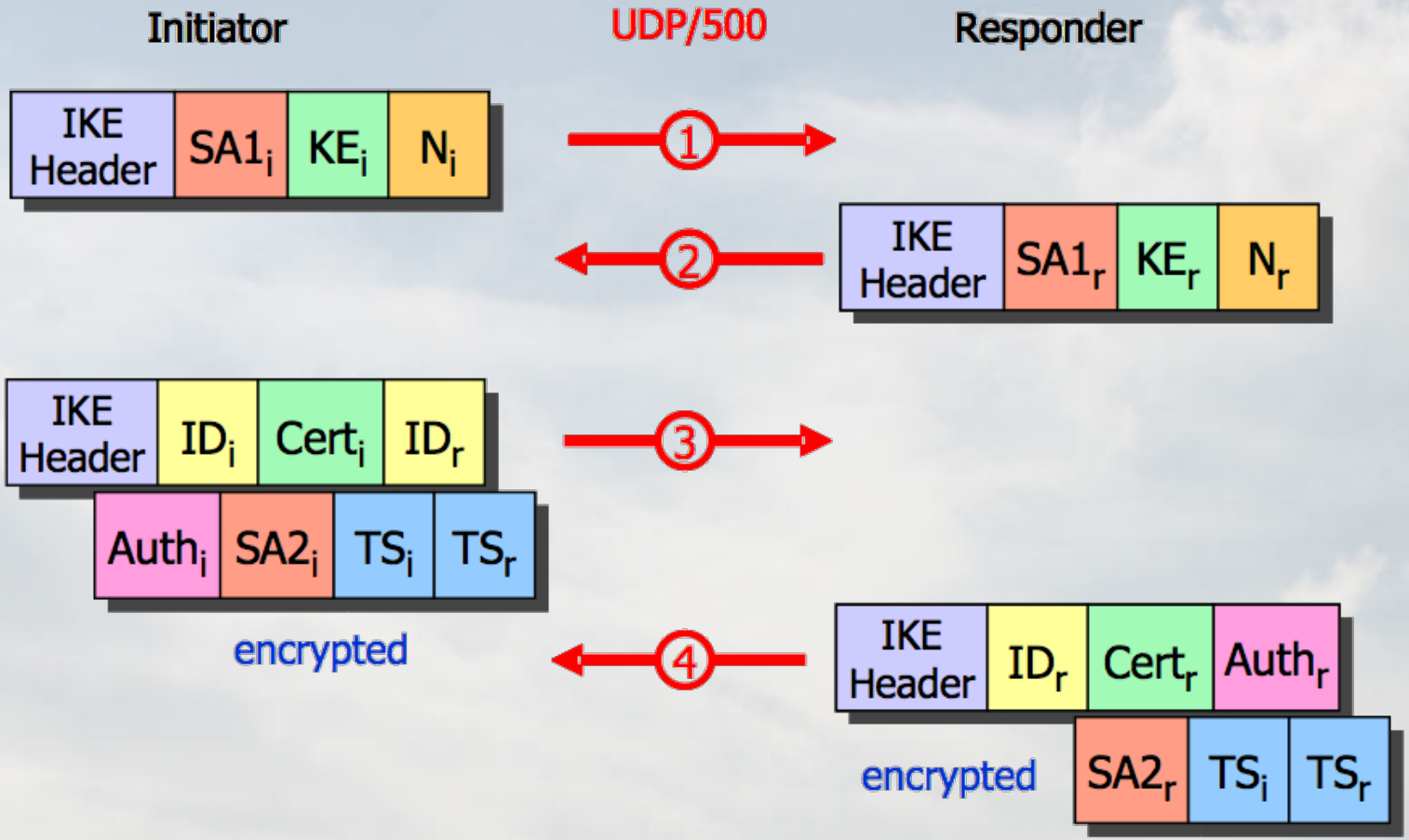
- Informar sobre estado y errores, SA eliminadas, negociación de datos de configuración

fuente: Giuseppe Bianchi, IPsec Basics

Understanding IPsec IKEv2 negotiation on Wireshark

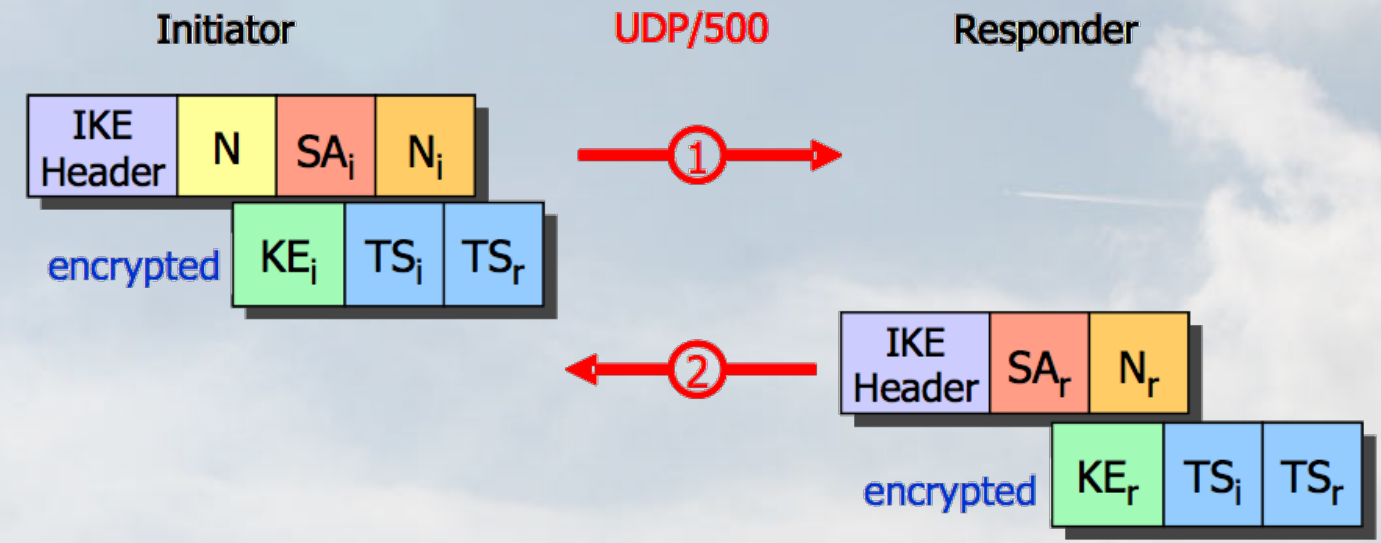


en detalle

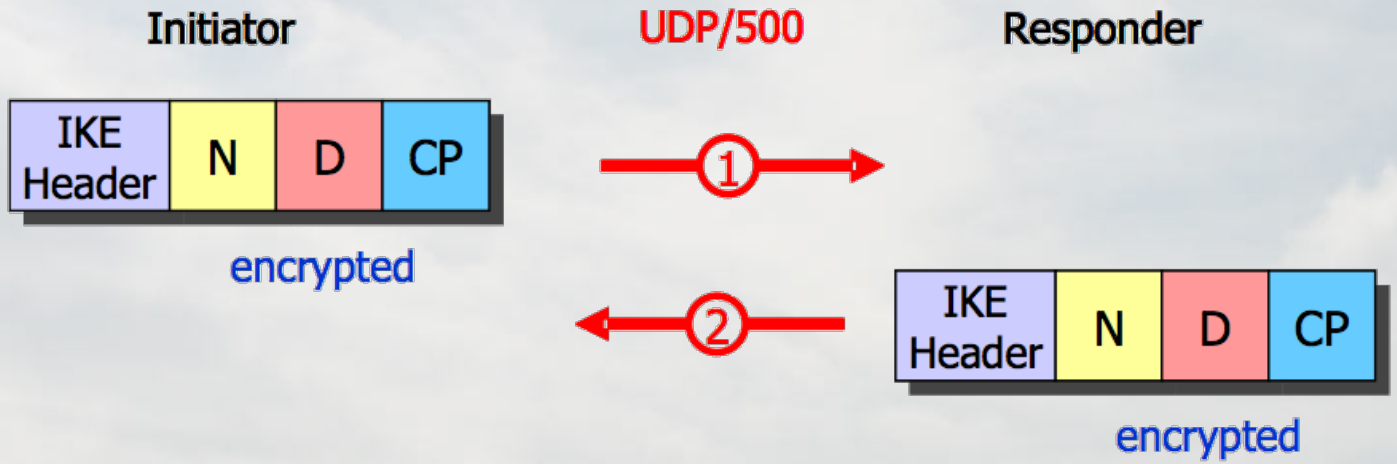


IKEv2 - IKE_SA_INIT and IKE_AUTH message exchanges

fuente: Internet Security, Andrea Steffen 2011



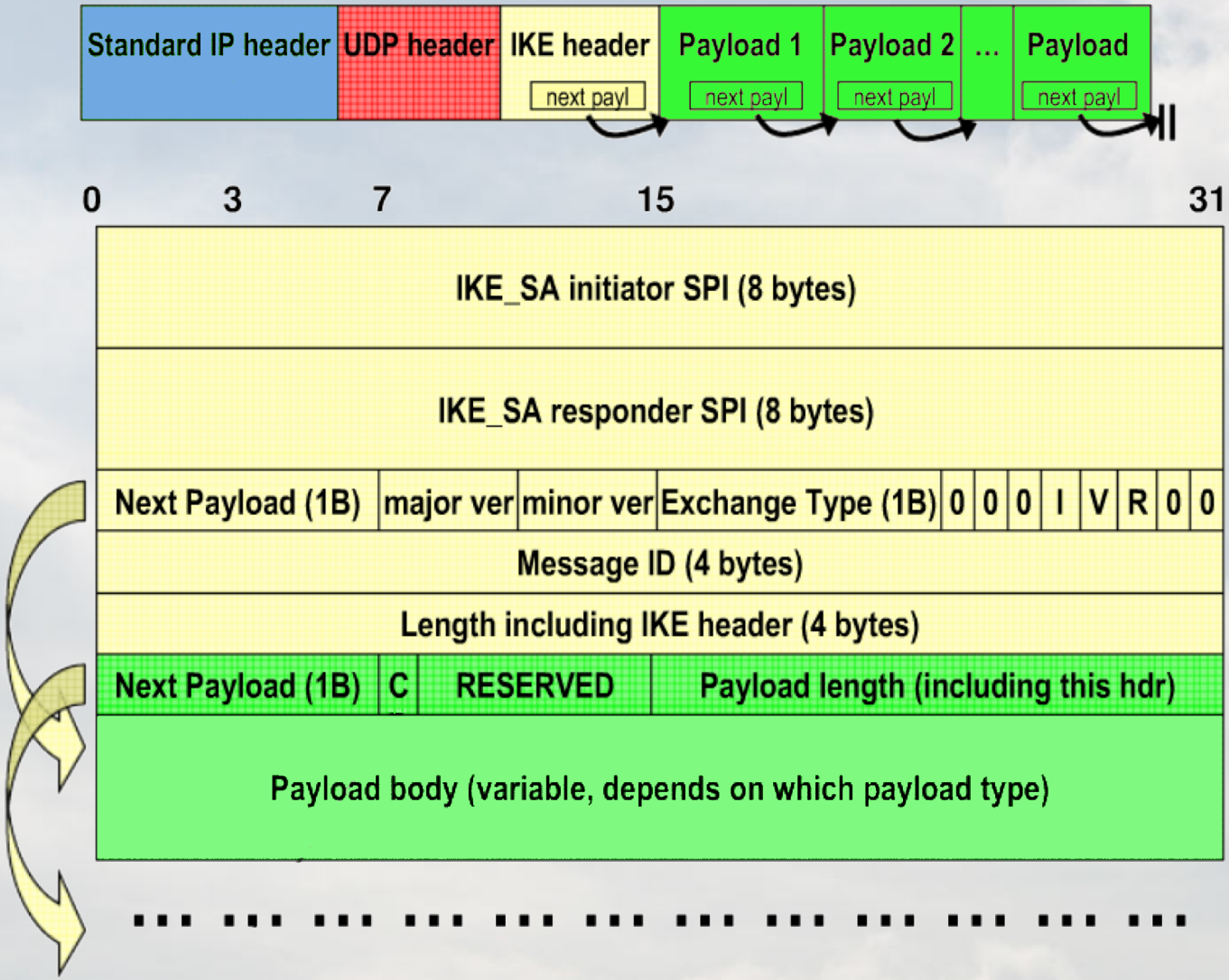
IKEv2 - CREATE_CHILD SA message exchange



IKEv2 - INFORMATIONAL message exchange

fuente: Internet Security, Andrea Steffen 2011

Formato mensajes IKEv2



fuente: Giuseppe Bianchi, IPsec Basics

IKEv2 y PQC

Someone storing VPN communications today could decrypt them at a later time when a quantum computer is available

- *RFC 8784: Mixing Preshared Keys in the Internet Key Exchange Protocol Version 2 (IKEv2) for Post-quantum Security (Jn20)*
  An extension of IKEv2 to allow it to be resistant to a quantum computer by using preshared keys
- *RFC 9242: Intermediate Exchange in the Internet Key Exchange Protocol Version 2 (IKEv2)*
  Defines a new exchange, called "Intermediate Exchange" that can be used for transferring large amounts of data in the process of IKEv2 Security Association (SA) establishment



- *RFC 9370: Multiple Key Exchanges in the Internet Key Exchange Protocol Version 2 (IKEv2) (My23)*
  Allows peers to perform one or more post-quantum key exchanges in conjunction with an (EC)DH key exchange so that the resulting shared key is resistant to quantum-computer attacks
- *RFC 9867: Mixing Preshared Keys in the IKE_INTERMEDIATE and CREATE_CHILD_SA Exchanges of the Internet Key Exchange Protocol Version 2 (IKEv2) for Post-Quantum Security (Nv25)*
  To also protects the initial IKEv2 SA
- *draft: Hybrid Post-Quantum and Traditional Authentication for IKEv2 (Fb27)*
  Defines a hybrid authentication mechanism for IKEv2 that combines traditional and post-quantum (PQC) signature algorithms using composite certificates



Combinaciones de asociaciones de seguridad

